



[INICIO](#) / [INCIBE-CERT](#) / [Blog](#) / IoT: protocolos de comunicación, ataques y recomendaciones

IoT: protocolos de comunicación, ataques y recomendaciones

Fecha de publicación 07/02/2019

Autor

Ignacio Porro Sáez (INCIBE)



[Actualización 01/08/2023]

El IoT (*Internet of Things*) es un concepto que engloba la interconexión de dispositivos y objetos cotidianos a través de Internet, permitiendo la recopilación y el intercambio de datos. La creciente popularidad de estos dispositivos ha dado lugar a desafíos significativos en cuanto a su seguridad. A continuación, haremos un análisis de los aspectos de seguridad que se deben tener en cuenta tanto a nivel de funcionamiento como de sus comunicaciones, detallando los distintos protocolos.

Protocolos de comunicación

Los dispositivos IoT utilizados tanto en entornos industriales, como en el entorno doméstico, pueden compartir aspectos de kernel (Linux, FreeRTOS, Windows Embedded, siendo el primero de ellos el más utilizado) y servicios de bajo nivel (*Real-Time Management*, *Context Discovery Management*), pero en términos de comunicación son muy diferentes. A continuación se explican algunos de los protocolos utilizados a nivel doméstico e industrial.

Entorno doméstico:

Cada día son más los hogares que disponen de uno o varios dispositivos IoT. Existen multitud de empresas que fabrican estos dispositivos. Cada uno tiene su propio protocolo de

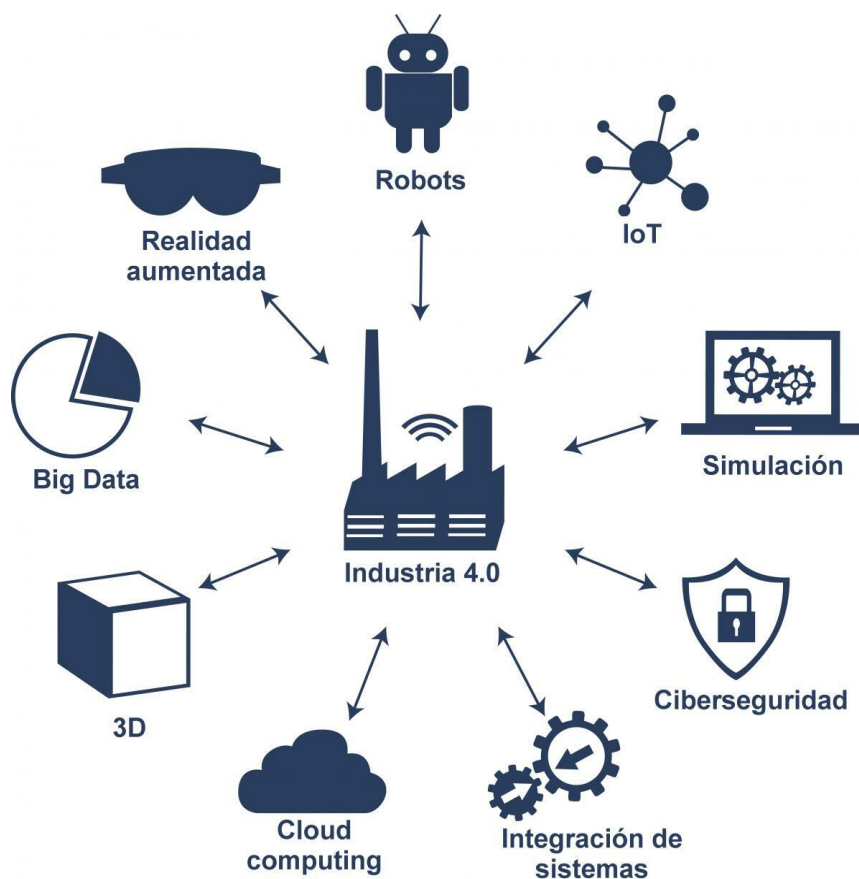
comunicación y aunque no es mucha la información que suelen facilitar, sobre todo si no son protocolos de código abierto, los más conocidos son:



- ◆ AllJoyn fue lanzado por The AllSeen Alliance, compuesta por Haier, LG, Microsoft, Panasonic, Qualcomm, Sharp, Silicon Image, Technicolor y TP-Link. Es un estándar de código abierto, que facilita la comunicación entre dispositivos y aplicaciones, para todo tipo de protocolos de la capa de transporte.
- ◆ HomePlug y HomeGrid son protocolos cuya comunicación se realiza a través de la red eléctrica. Esta tecnología de comunicación la implementan numerosas marcas. Dependiendo del producto adquirido, el tipo de cifrado es diferente, incluso algunos dispositivos transmiten la información sin cifrar.
- ◆ MFi (*Made For iPhone/iPod/iPad*) es un protocolo de comunicaciones propio de Apple diseñado para interactuar con estos dispositivos. Los dispositivos y elementos de conexión de Apple incorporan un chip mediante el cual verifican que tanto los dispositivos, como los cables de conexión son originales.
- ◆ OCF (*Open Connectivity Foundation*) es un protocolo impulsado por Samsung, Intel, Microsoft, Qualcomm, Electrolux entre otras. Es un proyecto de código abierto que ofrece interconectividad con la filosofía *just-works*. Este protocolo pretende garantizar la interoperabilidad de millones de dispositivos, gracias a una implementación de referencia (**IoTivity**) y un programa de certificación.
- ◆ Thread (*network protocol*) fue creado por el conjunto de empresas denominado Thread Group. Es una tecnología basada en las comunicaciones por red mediante IPv6 que utiliza cifrado AES. Por ello y por la flexibilidad que ofrece, es un protocolo muy seguro y está preparado para el futuro.

Entorno industrial:

Con la aparición de los dispositivos IoT, surge el concepto de **industria 4.0**. Podemos definirla como la digitalización completa a través de la integración de tecnologías de procesamiento de datos, software inteligente y sensores, desde los proveedores hasta los clientes. Pero para que esto sea posible, los dispositivos deben poder comunicarse, tanto entre sí, como hacia el exterior. Por ello comentamos algunos de los protocolos de comunicación existentes en la industria.



- ♦ **AMQP (Advanced Message Queuing Protocol)** es un protocolo del nivel 7 del modelo OSI para aplicaciones distribuidas que soporta comunicaciones punto-a-punto y de tipo publicación/suscripción. Proviene del sector de servicios financieros y tiene presencia en el ámbito de TI y en el sector industria, siendo bastante limitada en este último. Ofrece un modelo robusto de comunicaciones que soporta transacciones y puede garantizarlas de forma completa. Ofrece seguridad a través de la autenticación y cifrado mediante SASL o TLS.
- ♦ **CoAP (Constrained Application Protocol)** fue creado por IETF (*Internet Engineering Task Force*) para proveer la compatibilidad de HTTP con una mínima carga. Es un protocolo cliente/servidor, es similar a HTTP pero usa UDP/multicast en lugar de TCP, además de simplificar el encabezado reduce el tamaño de cada requerimiento. Desde el punto de vista de la seguridad utiliza DTLS (*Datagram Transport Layer Security*), que básicamente consiste en aplicar seguridad en la capa de transporte para proteger las comunicaciones.
- ♦ **DDS (Data Distribution Service)** es un protocolo de tipo publicación/suscripción concebido para sistemas de tiempo-real. Es un estándar abierto y descentralizado. Los nodos de DDS se comunican directamente punto a punto a través de UDP/multidifusión (*multicast*). DDS es una buena solución para aplicaciones que requieren intercambio de datos en tiempo real como el control del tráfico aéreo, gestión de redes inteligentes, vehículos autónomos, robótica, sistemas de transporte, generación de electricidad, etc. Ofrece seguridad a través de TLS, DTSL y DDS.
- ♦ **HTTP (REST/JSON) (Hypertext Transfer Protocol)** es un protocolo cliente/servidor sin conexión presente en las TIC y en la web. Es un protocolo muy accesible por ser de código abierto, además de poseer numerosas librerías. Es efectivo para enviar grandes cantidades de información, como por ejemplo lecturas de sensores minuto a minuto o cada hora; aunque no es adecuado ni para enviar actualizaciones en periodos de tiempo del orden de milisegundos ni para enviar información de video. Es muy recomendable asegurar la información transmitida aplicando el protocolo criptográfico SSL/TLS sobre HTTP, lo que genera el protocolo de aplicación HTTPS. No obstante, el método más seguro consiste en incluir en el dispositivo IoT solo un cliente HTTP, no un servidor HTTP, de manera que el dispositivo IoT pueda iniciar conexiones a un servidor

web, pero no sea capaz de recibir solicitudes de conexión.

- ♦ **MQTT (*Message Queuing Telemetry Transport*)** es un protocolo de tipo publicación/suscripción de nivel de aplicación con una versión para redes no basadas en TCP/IP (p. ej. Zigbee) denominada MQTT-SN. Este protocolo ha sido implementado en múltiples aplicaciones de IT, IoT y OT, como por ejemplo, el Messenger de Facebook, MS Azure IoT hub o para entornos de generación de electricidad mediante fuentes renovables. Puesto que MQTT envía credenciales de conexión en claro y no incluye en su diseño medidas de seguridad (p. ej. autenticación o cifrado) es recomendable usarlo con TLS para asegurar las comunicaciones en su versión sobre TCP, así como los mecanismos propios compatibles de comunicaciones no basadas en TCP/IP.
- ♦ **OPC UA (*Unified Architecture*)** es un estándar de nueva generación que surge a partir del OPC, el cual es conocido por proveer una interfaz estándar para comunicarse con los PLC. OPC UA es un protocolo cliente/servidor multiplataforma, donde los clientes se conectan, navegan, leen y escriben al equipamiento industrial. Ofrece un modo binario y otro basado en SOAP (Web Service). Las tecnologías y metodologías innovadoras, como los nuevos protocolos de transporte, los algoritmos de seguridad, los estándares de codificación o los servicios de aplicación pueden incorporarse en OPC UA mientras se mantiene la compatibilidad retroactiva para los productos existentes. Es una opción para conectar información de sensores y PLC en las aplicaciones industriales existentes como sistemas MES (*Manufacturing Execution System*) y SCADA (*Supervisory Control And Data Acquisition*). Este estándar implementa medidas de seguridad para las comunicaciones, como son autenticación de la aplicación, autenticación y autorización del usuario, disponibilidad del servidor, auditabilidad del sistema y confidencialidad e integridad, lo que lo convierte en un protocolo muy seguro. OPC UA ofrece seguridad nativa que incluye autenticación y autorización, cifrado e integridad de datos vía firmas. Para la versión SOAP hace uso de la especificación de seguridad para *Web Service* desarrollada por IBM, WS-SecureConversation, mientras que en la versión binaria hace uso de una implementación específica de la anterior. Soporta certificados X.509 para la autenticación y se puede integrar con directorio activo y PKI.
- ♦ **XMPP (*Extensible Messaging and Presence Protocol*)** es un protocolo abierto, escalable y descentralizado basado en XML, originalmente diseñado para mensajería instantánea. Las características de XML en cuanto a adaptabilidad y sencillez de XML han sido heredadas por el protocolo XMPP. Los servidores que utilizan este protocolo pueden estar aislados de la red pública XMPP, y poseen robustos sistemas de seguridad como SASL y TLS. Gran parte de los cortafuegos están configurados para permitir el tráfico TCP del puerto utilizado por HTTP, pero bloquean el puerto utilizado por XMPP, para solucionarlo XMPP utiliza HTTP para permitir el acceso a los usuarios que se encuentran tras un cortafuegos.

La tabla siguiente resume las características principales de algunos de estos protocolos:

	Transporte	Modelo	Ámbito de aplicación	Conocimiento del contenido	Datos principales	Seguridad	Prioridad de los datos	Tolerancia a fallos
AMQP	TCP/IP	Intercambio de mensajes punto a punto	D2D D2C C2C	Ninguno	Codificados	TLS	Ninguno	Específica de la implementación
CoAP	UDP/IP	Petición/Respuesta (REST)	D2D	Ninguno	Codificados	DTLS	Ninguno	Descentralizado
DDS	UDP/IP (unicast + mcast) TCP/IP	Publicación/Suscripción Petición/Respuesta	D2D D2C C2C	Enrutamiento basado en el contenido, consultas	Declarados codificados	TLS, DTLS, DDS	Prioridades de transporte	Descentralizado
MQTT	TCP/IP	Publicación/Suscripción	D2C	Ninguno	No definidos	TLS	Ninguno	El nodo central (broker) es el punto único de fallo (SPoF)

- Tabla comparativa sobre alguno de los protocolos -

Ataques

El auge de los dispositivos IoT y su gran interconexión les convierte en el objetivo perfecto para los ciberdelincuentes. El número de amenazas de malware ha crecido en este ámbito, no sólo de forma cuantitativa sino también cualitativamente ([GreyEnergy](#), [fuga de información a través de termostato](#), [GoAhead](#), [ataques DoS a través de cámaras IP](#)). Esto, unido a que los vectores de ataque pueden ser muy diferentes, hace que haya que tener en cuenta diferentes aspectos para protegerlos de manera adecuada y poder conectarlos a redes privadas. Algunos de estos vectores son:

- ◆ Ataque por fuerza bruta para «obtener» una clave, normalmente la utilizada por el protocolo Telnet. El cual es utilizado por algunos dispositivos de IoT para el acceso de forma remota.
- ◆ Ataques por denegación de servicio que producen indisponibilidad de los dispositivos por saturación.
- ◆ Utilización como plataforma de ataque hacia otros dispositivos del entorno, ya que por defecto suelen estar menos fortificados y son más accesibles desde el exterior de la red donde se encuentran.
- ◆ Obtención de datos de carácter personal de los usuarios como: hábitos de uso, contraseñas de acceso a servicios web e incluso datos de tarjetas de crédito.

Medidas de prevención

Para poder reducir el riesgo de la materialización de algunas de las amenazas que hemos descrito, debemos de implantar al menos las siguientes medidas:

- ◆ Actualizaciones y parches. Tener el [dispositivo actualizado](#) es importante para minimizar el riesgo de que éste sea vulnerable.
- ◆ Autenticación, control de accesos y administración. Evitar las contraseñas predeterminadas. Una [contraseña robusta](#) para acceder a la configuración del dispositivo es una buena medida contra accesos no deseados, así como administrarlos (en caso de que sea posible) solo de forma local.
- ◆ Protección de los datos almacenados. Se debe poder controlar qué datos almacenados dentro de nuestro dispositivo se envían a los fabricantes.
- ◆ Uso de protocolos seguros. Las comunicaciones con otros dispositivos y equipos deben hacerse a través de protocolos seguros.
- ◆ Bloquear puertos. Siempre y cuando sea posible, es recomendable desactivar todos aquellos que no se vayan a utilizar, para evitar brechas de seguridad.
- ◆ Plan de continuidad del servicio. Tener un dispositivo que pueda trabajar de forma autónoma, es decir, sin supervisión remota por si se produce un fallo en la red, es muy importante, así como que el dispositivo cuente con un sistema de logs que almacene datos en caso de producirse un fallo para investigar las causas del mismo.
- ◆ Segmentación de redes. Es clave para proteger el entorno IoT. Al dividir la red en subredes específicas (campo, áreas de producción y centros de control) y mantenerlas separadas de la red corporativa, se reduce el riesgo de propagación de amenazas. Además, se puede apoyar en políticas de control de acceso granulares y facilita la monitorización de actividades sospechosas.

Adicionalmente y en función del conjunto de dispositivos, sus particularidades y las opciones de seguridad de los mismos, estas medidas podrían extenderse para el mismo objetivo: protegerlos de manera adecuada.

[Actualización 01/08/2023]

Medidas de detección

Las medidas de detección son esenciales para anticiparse a posibles fallos u ataques, siendo fundamentales especialmente en las etapas tempranas de la gestión de incidentes. Por ello, la implantación de las siguientes medidas es muy recomendable:

- ♦ Monitorización en tiempo real: habilitar la monitorización continua de la red IoT y los dispositivos industriales para detectar actividad sospechosa o no autorizada.
- ♦ Detección basada en patrones: se basa en identificar patrones conocidos, firmas de eventos o comportamientos sospechosos. Por ejemplo, se pueden aplicar reglas basadas en detectar códigos de función no válidos, en actualizaciones de firmware, en dispositivos no autorizados en la red, en intentos de inicio excesivos, en **denegaciones de servicio**, en ausencia de tráfico en sensores o en tráfico de red compatible con muestras de malware IoT.
- ♦ Detección basada en anomalías: se centra en identificar desviaciones o anomalías en el comportamiento de la red IoT en comparación con un perfil de comportamiento normal o con una línea base establecida. Así, cualquier acceso de un dispositivo no habitual, la detección de tráfico inusual o una conexión fuera de horario, sería rápidamente registrada por el sistema.
- ♦ Configurar el registro de eventos: en la medida en la que la tecnología lo permita, es recomendable que los dispositivos IoT estén configurados para registrar eventos de seguridad relevantes (como la autenticación, los accesos o los permisos) o las funcionalidades del sistema, facilitando la detección y el análisis de incidentes.
- ♦ Inteligencia de amenazas y colaboración: establecer mecanismos de colaboración y compartir **IOC** sobre amenazas y vulnerabilidades con otras organizaciones y comunidades de seguridad. Esto incluye la participación en grupos de intercambio de información sobre amenazas, la suscripción a servicios de inteligencia de amenazas (como **ICARO**, para operadores estratégicos e instituciones afiliadas a RedIRIS) y la colaboración con expertos en seguridad. Esta práctica proporciona información actualizada sobre las últimas amenazas y tácticas de los atacantes, permitiendo a la organización anticiparse y adaptar sus sistemas de detección en consecuencia.
- ♦ Sistemas señuelo: elementos como *honeypots* o *canary tokens* sirven como señuelos en una estrategia de alerta temprana, que ayuda a revelar la presencia de atacantes y proporcionar información valiosa sobre sus tácticas, técnicas y procedimientos (TTP).

Conclusiones

La seguridad es un proceso importante que debe ser tenido en cuenta en todas las fases de vida de un dispositivo conectado, desde su diseño hasta el final de la vida útil. Antes de desechar un dispositivo debe realizarse algún procedimiento de borrado seguro de la información almacenada.

Si no se tienen en cuenta las medidas de protección del apartado anterior, podemos ser víctimas de un incidente de ciberseguridad que podría afectar tanto al dispositivo mencionado, como a los cercanos.

Todas las indicaciones mencionadas pueden ser aplicadas tanto a dispositivos de uso personal, como de uso industrial, siendo estos últimos los que presentan una mayor criticidad por encontrarse en grandes empresas o en infraestructuras críticas, lo cual aparte de graves daños económicos puede suponer un riesgo para las personas y/o el medio ambiente.

iOS

IoT

Protocolo industrial

Smart Grid

+



Tags INCIBE-CERT

+